

Due-Diligence Report: repo_6

Self-audit passed — every finding this report gathered is cited below.

Verdict: 7/10 — Est. 20-36 engineer-hours to acquisition-ready

repo_6 (CoolReader) is a cross-platform C++ e-book reader with GPL-2.0 license and active maintenance. Secret scan flagged hardcoded secret findings in production files including android\app\build.gradle, android\jni\cr3java.cpp, android\res\layout\catalog_edit_dialog.xml. Total remediation cost is estimated at 28 hours (range 20-36h).

Remediation Cost Estimate

Item	Hours	Basis
Rotate 20 hardcoded credential(s) found in production code	20	1h per finding (rotate + remove from code + wire to secrets manager)
Stand up a working automated test suite	8	Flat estimate — tests did not run successfully during audit

Total: 28 hours (range: 20-36h)

Heuristic estimate based on the stated per-item assumptions above, not a professional engineering quote. Presented as a range (20-36h) to avoid false precision. Does not include general code-quality improvements beyond the specific findings listed.

Risks

- Hardcoded secret / credential finding in non-test file android\app\build.gradle.
Secret scan: file android\app\build.gradle line 40 type High-entropy string (possible secret) in_test_dir: false.
- Hardcoded secret / credential finding in non-test file android\jni\cr3java.cpp.
Secret scan: file android\jni\cr3java.cpp line 305 type High-entropy string (possible secret) in_test_dir: false.
- Hardcoded secret / credential finding in non-test file android\res\layout\catalog_edit_dialog.xml.
Secret scan: file android\res\layout\catalog_edit_dialog.xml line 81 type Hardcoded value assigned to 'password' (low-entropy — not caught by randomness check) in_test_dir: false.
- Hardcoded secret / credential finding in non-test file android\res\layout\online_store_login_dialog.xml.
Secret scan: file android\res\layout\online_store_login_dialog.xml line 109 type Hardcoded value assigned to 'password' (low-entropy — not caught by randomness check) in_test_dir: false.
- Hardcoded secret / credential finding in non-test file android\res\layout\online_store_new_account_dialog.xml.
Secret scan: file android\res\layout\online_store_new_account_dialog.xml line 108 type Hardcoded value assigned to 'password' (low-entropy — not caught by randomness check) in_test_dir: false.
- Hardcoded secret / credential finding in non-test file android\src\org\coolreader\db\MainDB.java.
Secret scan: file android\src\org\coolreader\db\MainDB.java line 547 type Hardcoded value assigned to 'password' (low-entropy — not caught by randomness check) in_test_dir: false.

- Hardcoded secret / credential finding in non-test file cr3gui\src\cr3xcb.cpp.
Secret scan: file cr3gui\src\cr3xcb.cpp line 119 type High-entropy string (possible secret) in_test_dir: false.
- Hardcoded secret / credential finding in non-test file crengine\src\pdbfmt.cpp.
Secret scan: file crengine\src\pdbfmt.cpp line 712 type High-entropy string (possible secret) in_test_dir: false.
- Hardcoded secret / credential finding in non-test file thirdparty_repo\freetype.meta.sh.
Secret scan: file thirdparty_repo\freetype.meta.sh line 10 type High-entropy string (possible secret) in_test_dir: false.
- Hardcoded secret / credential finding in non-test file thirdparty_repo\fribidi.meta.sh.
Secret scan: file thirdparty_repo\fribidi.meta.sh line 10 type High-entropy string (possible secret) in_test_dir: false.
- Hardcoded secret / credential finding in non-test file thirdparty_repo\harfbuzz.meta.sh.
Secret scan: file thirdparty_repo\harfbuzz.meta.sh line 10 type High-entropy string (possible secret) in_test_dir: false.
- Hardcoded secret / credential finding in non-test file thirdparty_repo\libjpeg.meta.sh.
Secret scan: file thirdparty_repo\libjpeg.meta.sh line 10 type High-entropy string (possible secret) in_test_dir: false.
- Build and test checks were not supported for C++ language.
Build/test evidence: attempted: false, reason: No deep build/test support for cpp.

Strengths

- GPL-2.0 project license detected.
License check: project_license: {found: true, license: GPL-2.0}.
- Active GitHub maintenance and contributors.
GitHub activity: days_since_last_push: 32, contributor_count: 45.

License

Project license: **GPL-2.0**

Ownership & Continuity Risk

45 contributor(s), top contributor: 43.7% of commits, last push: 32 days ago

Could Not Verify

- Dependency vulnerability and dependency license checks because no Python/npm manifest was detected.

Every claim above is backed by evidence in the full JSON report.